

Security & Privacy Posture Statement

All technical and organisational measures protecting personal data — Act 90/2018, Act 55/2009, Act 40/2007, GDPR

Version: v1.7 **Last updated:** 10 June 2026 **Controller:** Lifeline Health ehf.

Language: English companion — the Icelandic original prevails

This document describes all technical and organisational security measures that Lifeline Health ehf. has in place to protect personal data, in accordance with Icelandic Act No. 90/2018 on Data Protection, Act No. 55/2009 on Medical Records, Act No. 40/2007 on Health Services, and Regulation (EU) 2016/679 (GDPR). It is intended for audits by Persónuvernd (the Icelandic DPA), for legal counsel, and for B2B customers assessing our security posture before entrusting us with their employees' data.

1 Entity and contact

ROLE	DETAILS
Data controller	Lifeline Health ehf. · Reg. no. (kennitala) 590925-1440 · Langholtsvegur 111, 104 Reykjavík, Iceland · contact@lifelinehealth.is · www.lifelinehealth.is
Data Protection Officer	Mads Christian Aanesen, CTO and founder · contact@lifelinehealth.is
Supervisory authority	Persónuvernd · postur@personuvernd.is · www.personuvernd.is — data subjects may lodge complaints directly
Other regulators	Directorate of Health (healthcare licence, Act 41/2007); Icelandic Health Insurance where applicable

2 Scope of service

Lifeline Health operates a licensed healthcare service (health assessments, blood tests, body-composition measurements, doctor consultations, training and counselling) under Act No. 40/2007. Technically the service consists of three layers:

- **Lifeline app + admin** — operational tooling (bookings, training plans, coach messaging, self-tracking). Data protection under Act 90/2018. *Not a medical record.*
- **Medalia** — medical-records system licensed under Act 55/2009, hosting clients' formal medical records. Joint controllership under GDPR Art. 26.
- **Biody Manager** — external measurement device + cloud service for raw body-composition data. Processor under GDPR Art. 28.

3 Lawful basis

DATA	BASIS
Personal data	Art. 6(1)(b) contract performance · Art. 6(1)(c) legal obligation (Acts 55/2009, 40/2007, tax law) · Art. 6(1)(f) legitimate interests (security, incident management, debugging)
Health data (Art. 9)	Art. 9(2)(a) explicit consent · Art. 9(2)(h) healthcare by professionals bound by confidentiality (Act 34/2012)
Marketing / research	Art. 6(1)(a) separate opt-in consent, revocable at any time

4 Data categories

- **General personal data** (Lifeline Supabase): name, email, phone, address, date of birth; **last 4 digits of the kennitala only** — the full national ID is never stored (data minimisation, Art. 5(1)(c)); subscription status, bookings, payments.
- **Special categories (Art. 9)**: medical-record data lives in Medalia; raw body-composition data lives in Biody Manager and is fetched on demand with explicit consent (no persistent storage in Lifeline since 2026-05-03); coach-client messages (may contain health information) are stored **encrypted** in the Lifeline database.
- **Wellness data**: self-logged weight, activity, meals, reflections; plans, scores, completions.
- **Staff and business data**: staff records (role, licences, contracts); B2B company data (contracts, invoices, employee rosters).

5 Hosting & data location

PROVIDER	ROLE	LOCATION
Medalia ehf.	Medical-records system (EHR)	Iceland
Biody Manager	Body-composition measurements	France (EEA)
Supabase Inc.	Database, authentication	Germany (EEA)
Vercel Inc.	Web hosting, frontend services	EEA + USA (SCC)
Resend (Lilo Labs)	Email delivery	EEA + USA (SCC)

All parties outside the EEA rely on Standard Contractual Clauses under GDPR Art. 46.

6 Encryption

In transit

- TLS 1.3 on all public endpoints (managed by Vercel).
- Internal calls to the Biody-sync edge function require **both** a service-role bearer token (Supabase gateway JWT check) **and** an HMAC signature (`X-Lifeline-Signature`). Defence in depth: a leaked service-role key alone cannot forge a call.

At rest

- Supabase storage layer encrypted by default (AES-256, AWS KMS).
- **Column-level encryption** on top for Art. 9 and PII data: `messages.content` and `clients.phone / address / date_of_birth / emergency_contact_* / kennitala_last4`, using pgcrypto `pgp_sym_encrypt` (AES-256) with the key held in Supabase Vault. Only SECURITY DEFINER helper functions can retrieve the key. Plaintext columns were dropped on 2026-05-03; only encrypted BYTEA columns remain.
- Signed PDF documents (staff, client-consent, legal-signoff, platform, company) live in private Supabase Storage buckets, each with dedicated RLS policies.

7 Access controls

Authentication

- Supabase Auth: bcrypt-hashed passwords; password double-entry on every flow that sets a password (B2C/B2B signup, password change, invite claims).
- Email confirmation runs on Lifeline's own domain via `token_hash + verify0tp` — raw Supabase action links are never emailed (no live sign-in links in third-party mailboxes).
- **Staff: mandatory TOTP two-factor (AAL2)** before any admin access. Exception: external lawyers (role `lawyer`) who only reach `/admin/legal/*` (no patient data); their signatures are evidenced by authenticated session, IP logging, SHA-256 of the document text and a stored PDF certificate.

Role-based access (RBAC) and specialty separation

- Roles: `coach`, `doctor`, `nurse`, `psychologist`, `admin`, `lawyer`, `medical_advisor` — each with its own Row Level Security policies in PostgreSQL.
- Clinicians see clinical communications; coaches see the coaching surface; admin has operational superuser rights.
- **Lawyer:** legal drafts and signoff system only. **Medical advisor:** read-only across the admin (MFA required); all writes blocked in both RLS and API gates.

Pre-launch site access gate

- The marketing site is closed until launch. Access via an admin-managed ACL: per-user/company/group grants with optional expiry, ad-hoc cohort groups, and shareable invite tokens stored **only as SHA-256 hashes**. Validation runs in SECURITY DEFINER functions. The previous hardcoded preview key was fully removed on 2026-06-02.

STATED PLAINLY

The pre-launch gate protects marketing content — it is **not** a security boundary for personal data. All data remains protected by authentication, RLS and API gates regardless of it.

Quarterly access review

- Every active staff member is reviewed every 90 days; automatic overdue reminders; each decision recorded with before/after role and permissions.

8 Audit logging & error logging

- **health_audit_log**: append-only entries for every INSERT/UPDATE/DELETE on clients, messages, weight logs and body-composition events, written by automatic Postgres triggers (cannot be bypassed by application code). Records actor identity, role, action, table, row and timestamp. Retention: 6 years per Act 55/2009 §13. Admin-only read.
- **Error logging is fully in-house** (no third-party service; Sentry removed 2026-06): frontend and backend errors are written directly to `app_errors` in Supabase (EEA). Kennitala values and email addresses are regex-scrubbed before storage on **both** paths; cookies, headers and request bodies are never captured. Triage in `/admin/errors` + a daily email digest.

9 Data subject rights

Clients hold the full set of GDPR rights (access, rectification, erasure — limited for medical records, restriction, objection, portability, consent withdrawal).

- Requests are submitted in plain language via the account area ("Make a privacy request"), stored in `dsr_requests`, and emailed to the DPO with an action checklist and the 30-day deadline (Art. 12(3)).
- Admin manages the workflow with status transitions; a documented runbook holds the procedure and SQL for every request type.

10 Processors & joint controllers

PARTY	RELATIONSHIP	STATUS
Medalia ehf.	Joint controller (Art. 26)	DPA signed; joint-controller arrangement drafted, under counsel review
Aminogram SAS (Biody)	Processor (Art. 28)	Processing agreement pending signature
Supabase Inc.	Processor (Art. 28)	DPA accepted via terms of service
Vercel Inc.	Processor (Art. 28)	DPA accepted via terms of service
Resend (Lilo Labs)	Processor (Art. 28)	DPA accepted via terms of service

11 Breach response

- 72-hour notification duty to Persónuvernd (Art. 33); client notification per Art. 34 where required.
- All staff are contractually bound (signed at onboarding) to report suspected incidents immediately to the DPO, who assesses severity and notification duty.
- Incidents are recorded in the audit log plus a dedicated incident report where applicable; the in-house error-logging system provides the technical view.

12 DPIA

DPIA-lite for the wellness-mode interim architecture (until the Medalia API), signed by the DPO and stored in the legal archive. Review cadence: annually or on any major data-flow change. Next review: 2027-05-04.

13 Staff training & contracts

- Before access: every staff member e-signs (Act 28/2001) an NDA, a device & access policy, privacy training, and an onboarding checklist. Clinical staff additionally sign a confidentiality declaration under Act 34/2012. External lawyers sign NDA + privacy training only.
 - Every signature is preserved with a SHA-256 hash of the contract text, signer IP and browser fingerprint, timestamp, and a fully traceable PDF in a private bucket.
-

14 Client consent

- Granular, per-purpose consent stored with key, version, text hash, grant/revoke timestamps, IP and user agent; a PDF certificate is generated and emailed; revocable at any time.
 - Key consents: health-assessment consent (required for all assessments) and `biody-import-v1` (on-demand fetch of body-composition data, never stored).
-

15 Cookies & analytics

Only strictly necessary cookies (the Supabase Auth session token). No advertising cookies, no cross-site tracking. Any future analytics: anonymised aggregate only.

16 Architecture — wellness vs. medical record

CORE POINT FOR A DPA AUDIT

The Lifeline app is a **wellness dashboard, not a medical record**. Users see their own self-tracking, bookings, plans and coach messages — never clinical assessments or doctors' letters. A prominent in-app notice states: "This is your self-tracking dashboard — not your medical record."

- The medical record lives in Medalia (Act 55/2009), with access control and audit logging per §14 of that act.
- Body composition is fetched on demand from Biody after explicit consent; no persistent copies in Lifeline since 2026-05-03 — the same pattern intended for the Medalia API.
- **Planned (in progress, not yet live):** a direct Medalia ↔ Biody API integration. Once operational, measurements flow straight into the EHR and the Biody connection on the Lifeline admin side is retired — further shrinking health-data flow through the Lifeline layer. The app's on-demand, consented fetch remains. No system change has been made yet.

17 Evidence map — where the auditor finds what

WHAT	TABLE / STORAGE
DPIA	<code>company_documents</code> (kind='dpia')
Joint controller + DPAs (Medalia, Body)	<code>company_documents</code> (kind='joint_controller' / 'dpa')
B2B service agreements	<code>b2b_agreements</code> + <code>b2b_purchase_orders</code>
Staff signed agreements	<code>staff_agreement_acceptances</code> + private PDF bucket
Client consents	<code>client_consents</code> + private PDF bucket
Lawyer signoffs	<code>legal_review_signoffs</code> + private PDF bucket
Health-data audit trail	<code>health_audit_log</code>
Access reviews	<code>staff_access_reviews</code>
Data subject requests	<code>dsr_requests</code>
Pre-launch access grants	<code>access_grants</code> + <code>access_invite_tokens</code> (SHA-256)
Privacy incidents	<code>health_audit_log</code> + <code>app_errors</code> (/admin/errors)

18 Technical and organisational measures — summary

Technical

- ✓ Column-level encryption of Art. 9 and PII data (pgcrypto + Vault)
- ✓ Row Level Security on every table holding personal data
- ✓ MFA (TOTP / AAL2) mandatory for all staff with patient-data access
- ✓ TLS 1.3 on all public endpoints
- ✓ HMAC signing of internal service calls (with service-role bearer — neither suffices alone)
- ✓ Email confirmation via verifyOtp on our own domain (no raw action links)
- ✓ Password double-entry in every password-setting flow
- ✓ Admin-managed pre-launch access list (tokens stored only as SHA-256 hashes)
- ✓ PII scrubbing in in-house error logging — no error data leaves for third parties
- ✓ Audit log via Postgres triggers (traceability per Act 55/2009)
- ✓ Daily encrypted backups (Supabase pg_dump → Storage)
- ✓ Automatic error logging and incident management

Organisational

- ✓ Written agreements with all processors (Art. 28)
- ✓ Joint controller (Medalia) with a written arrangement

- ✓ Mandatory privacy training for all staff
- ✓ Clinical confidentiality declaration for health professionals
- ✓ Onboarding checklist with day-to-day rules + incident reporting
- ✓ Periodic (90-day) staff access reviews
- ✓ Lawful kennitala handling (only last 4 digits stored)
- ✓ DPIA for high-risk processing, signed by the DPO
- ✓ DSR process with SLA and a documented runbook
- ✓ Legal counsel reviews legal drafts before signature

19 Changelog

VERSION	DATE	CHANGE
v1.7	2026-06-10	Planned Medalia ↔ Biody API integration documented (plan only; admin-side Biody connection to be retired, app-side on-demand fetch stays).
v1.6	2026-06-10	Sentry fully removed; in-house error logging documented (one fewer subprocessor); PII scrubbing confirmed on both paths; DPO title corrected to CTO.
v1.5	2026-06-10	English companion rendering added; role list corrected to include medical_advisor.
v1.4	2026-06-10	Pre-launch access ACL replaces hardcoded preview key; auth-flow hardening (password double-entry, own-domain verifyOtp); Biody-sync dual auth confirmed; B2B login email decoupled from HR email.
v1.3	2026-05-16	Post-assessment feedback survey: lawful basis, encryption, 3-year retention with purge function, DSR runbook coverage.
v1.2	2026-05-04	External lawyer exempted from AAL2 (legal archive only); signature evidence via session, IP, SHA-256 and PDF certificate.
v1.1	2026-05-04	Registered address updated across all legal documents.
v1.0	2026-05-04	Initial release after external audit + remediation sprints: RLS hardening, audit log, DSR workflow, consent system, column encryption, MFA enforcement, quarterly access review.